

FrameworkPE — Classificação de Vulnerabilidades em Containers Docker

AI Horizon Labs · PPGES · UNIPAMPA · SBSeg 2026

Extensão do FrameworkPE para classificação automatizada de vulnerabilidades identificadas em containers Docker Hub a partir de relatórios do scanner OpenVAS/Greenbone. O dataset conta com **6.000+ registros** de vulnerabilidades com campos estruturados (CVSS, CVEs, Solution Type) e textuais (Summary, Vulnerability Insight, Impact, Solution).

Contexto

O **FrameworkPE** (ERRC 2025) demonstrou até 61,7% de acurácia na classificação de incidentes de segurança segundo a taxonomia NIST SP 800-61r3 usando técnicas de Prompt Engineering em LLMs e SLMs on-premise. Este repositório aplica o mesmo framework ao domínio de vulnerabilidades em containers, testando 5 técnicas de PE em 5 experimentos complementares.

Modelo

Todos os experimentos usam:

```
models:
- name: "qwen:0.5b"
  provider: ollama
  temperature: 0.2
  max_tokens: 2048
```

PROF

Técnicas de Prompt Engineering

Sigla	Nome	Estratégia
PHP	Progressive Hint Prompting	Itera com respostas anteriores como dicas progressivas até convergir
SHP	Self-Hint Prompting	O modelo elabora um plano antes de classificar e se auto-refina
PRP	Progressive Rectification Prompting	Mascara keywords e força reclassificação (quebra anchor bias)
ZSL	Zero-Shot Learning	Classificação direta sem exemplos — linha de base

Sigla	Nome	Estratégia
HTP	Hypothesis Testing Prompting	Testa H_true/H_false para cada categoria por palavras-chave

Experimentos

Exp	Nome	Tarefa	Ground Truth	Prioridade
E1	Severidade CVSS	Critical/High/Medium/Low/Informational	Automático (campo Severity)	Alta — comparação direta com paper base
E2	Tipo de Solução	VendorFix/WillNotFix/Workaround/Mitigation	Automático (campo Solution Type)	Alta — valor prático imediato
E3	Ablation de Input	Igual ao E1, variando campos de entrada	Automático (campo Severity)	Média — contribuição metodológica
E4	Priorização Container-Aware	Crítico/Alto/Médio/Baixo (contexto Docker)	Derivado por regras	Alta — contribuição original nova
E5	Cross-Domain Transfer	Igual ao E1, variando nível de adaptação	Automático (campo Severity)	Média — argumento de generalidade

PROF

Recomendação de execução: E1 + E4 (resultados principais) → E3 (aprofundamento metodológico) → E5 (generalidade).

Detalhes dos Experimentos

E1 — Classificação de Severidade CVSS

- **Input:** NVT Name + Summary + Vulnerability Insight + Impact (sem CVSS numérico)
- **Classes:** Informational / Low / Medium / High / Critical
- **Técnicas:** ZSL, PHP, SHP, HTP, PRP
- **Hipótese:** ranking **PHP > SHP > PRP > ZSL > HTP** se mantém no novo domínio
- → [Ver experimento_1/](#)

E2 — Classificação do Tipo de Solução

- **Input:** NVT Name + Summary + Solution + Affected Software/OS
- **Classes:** VendorFix / WillNotFix / Workaround / Mitigation
- **Variação:** rodar sem campo **Solution** para simular cenário zero-day
- → [Ver experimento_2/](#)

E3 — Ablation de Configurações de Input

Testa 5 configurações de entrada crescentemente ricas para a task de Severidade (E1):

Conf	Campos	Propósito
C1	NVT Name	Limite inferior
C2	+ Summary + Vulnerability Insight	Contexto textual
C3	+ CVEs	Referências externas
C4	+ Port + Affected Software/OS	Contexto de implantação
C5	+ CVSS numérico	Limite superior (upper bound)

- → [Ver experimento_3/](#)

E4 — Priorização Container-Aware

Taxonomia original para DevSecOps derivada automaticamente por regras:

Crítico-Container

Alto-Remediável

Médio-Monitorar

Baixo-Aceitar

← CVSS ≥ 9.0 AND WillNotFix AND tcp

← CVSS ≥ 7.0 AND VendorFix

← CVSS ∈ [4.0, 7.0)

← CVSS < 4.0 OR QoD < 50

- → [Ver experimento_4/](#)

PROF

E5 — Transferência Cross-Domain

Mede o ganho incremental de performance por nível de adaptação dos prompts:

Nível	Descrição	Hipótese
L0	Prompts NIST aplicados a vulnerabilidades (sem adaptação)	~Random
L1	Taxonomia trocada para CVSSv3	Ganho significativo
L2	+ contexto OpenVAS/scanner	Ganho moderado
L3	Prompts redesenhados para vulnerabilidades	Referência superior

Total: 5 técnicas × 4 níveis = **20 schemas**.

- → [Ver experimento_5/](#)

Dataset

- **Arquivo:** `openvas_experiments_dataset.csv` (6.000+ vulnerabilidades)
- **Arquivo reduzido:** `10_openvas_experiments_dataset.csv` (10 amostras para testes rápidos)
- **Fonte:** Scans OpenVAS/Greenbone de containers Docker Hub
- **Campos-chave:** IP, Hostname, Port, Port Protocol, CVSS, Severity, QoD, Solution Type, NVT Name, Summary, Specific Result, CVEs, Impact, Solution, Affected Software/OS, Vulnerability Insight

Documentação completa das colunas: [colunas_base.txt](#)

Instalação

```
python3 -m venv venv
source venv/bin/activate
pip install --upgrade --force-reinstall
git+https://github.com/AILabs4All/FrameworkPE.git@cli
```

Execução (por experimento)

```
cd experimento_1/          # ou experimento_2/, 3/, 4/, 5/
pg apply                   # aplica configurações (copia plugins)
pg run                     # executa todas as técnicas configuradas
ls output/                 # verifica resultados
```

Estrutura do Repositório

```
vulnerabilidades_classificao/
├─ openvas_experiments_dataset.csv      # Dataset completo (6k+ vulns)
├─ 10_openvas_experiments_dataset.csv  # Amostra para testes
├─ colunas_base.txt                     # Documentação das colunas
├─ experimento_1/                       # E1 – Severidade CVSS
├─ experimento_2/                       # E2 – Tipo de Solução
├─ experimento_3/                       # E3 – Ablation de Input
├─ experimento_4/                       # E4 – Priorização Container-
Aware
├─ experimento_5/                       # E5 – Cross-Domain Transfer
├─ logs/                                # Logs globais
├─ venv/                                # Ambiente virtual Python
└─ README.md
```